Threat Model and Security Control Mapping

Privacy-preserving federated learning for healthcare

01 Trust & adversary (ATTACK SOURCE)	02 Threat (RISK SCENARIO)	03 Security control (PRIMARY MITIGATION)
HC Honest-but-curious aggregation server	T1 Gradient reconstruction	M1 CKKS encryption + aggregate-only threshold decryption
	T2 Membership and property inference	M2 Gradient clipping + DP accountant
	T9 Blockchain metadata leakage	M9 Permissioned ledger, pseudonymous IDs and hash-only on-chain records
MC Malicious or compromised hospital client	T3 Model poisoning and backdoor	M3 Bound proof, reputation weighting, aggregate validation and rollback
	T4 Sybil and reputation manipulation	M4 Consortium CA, unique identities and admission control
	T7 Client dropout and availability failure	M7 Quorum, timeout and dropout-tolerant threshold
NET External network attacker	T5 Tampering, MITM and replay	M5 Mutual TLS, signatures, nonce, round ID and timestamp
	T8 DoS and resource exhaustion	M8 Rate limiting, quotas, circuit breaker and monitoring
COL Colluding participants	T6 Key compromise or collusion	M6 t-of-n key shares, HSM, rotation and revocation
BC Faulty administrator or smart-contract vulnerability	T10 Smart-contract logic failure	M10 Contract audit, multisignature upgrade and emergency pause
	T12 Consent violation or revoked-data use	M12 Consent registry, purpose binding, revocation and retention enforcement
USER Malicious inference user	T11 Inference extraction and abuse	M11 Authentication, query limits, minimal output and inference audit

Reading direction: adversary or failure source > threat scenario > primary mitigating control

Threats are grouped by source to improve traceability and eliminate crossing paths.